

REPORT GDPR · ESEMPIO ANONIMIZZATO

Valutazione privacy tecnica e documentale

Gestionale web (caso reale anonimizzato)

Riscontrato **Ipotesi** **Non verificabile**

OGGETTO	Repository del cliente (esempio)
VERSIONE ESAMINATA	commit esempio0001
MODALITÀ	solo analisi statica e documentale
DATA	2026-10-30
PREPARATO DA	Claude con gdpr-sentinel
CLASSIFICAZIONE	ESEMPIO · RISERVATO

Documento riservato. Non costituisce certificazione né parere legale.

Indice

Sintesi per il proprietario 2
Audit documentale 3
Valutazione privacy (GDPR/ePrivacy) 4
Domande per titolare, DPO, legale e fornitori 6
Copertura e limiti 7
Piano di intervento proposto 8

1 Sintesi per il proprietario

- Matrice A–N: 14 controlli, 4 non verificabili perché dipendono da documenti o decisioni del titolare.
- Punto concreto: l'informativa dice «server in UE, nessun trasferimento extra-SEE» e non nomina destinatari; il codice usa Google (font, backup) e Twilio.
- Dodici domande già formulate per titolare, DPO, legale e fornitori.
- Dati particolari: il modello delle assenze comprende certificati medici; i backup su un servizio cloud non risultano cifrati nella documentazione letta.
- Il report non esprime giudizi di conformità: le decisioni spettano al titolare.

2 Audit documentale

Confronto tra ciò che i documenti affermano e ciò che risulta da codice e configurazione, più completezza e aggiornamento dei documenti.

Esito: 4 non verificabile, 1 incoerente, 1 mancante su 6 voci esaminate.

ID	DOCUMENTO	STATO	RILIEVO E AZIONE
D01	Pagina privacy dell'applicazione (non datata)	INCOERENTE	Informativa non coerente col trattamento reale. Azione: Aggiornare l'informativa con i destinatari reali
D02	DPIA (v2.1, 03/2026)	NON VERIFICABILE	Possibile scostamento tra trattamenti reali e valutazione. Azione: Verificare con il DPO
D03	Guide ai backup (non datate)	NON VERIFICABILE	Rischio per i dati dei certificati medici. Azione: Verificare cifratura e test di ripristino
D04	Procedura di violazione dei dati (02/2026)	NON VERIFICABILE	Applicabilità ed esercitazioni non verificate. Azione: Verificare con il titolare
D05	Registro dei trattamenti	MANCANTE	Può essere custodito altrove dal titolare. Azione: Chiedere al titolare se esiste
D06	Accordo sindacale sulle timbrature (non datato)	NON VERIFICABILE	Dipende dal singolo cliente. Azione: Verificare per ogni cliente

3 Valutazione privacy (GDPR/ePrivacy)

Analisi tecnica e documentale: non è un parere legale e non esprime giudizi di conformità. Le decisioni spettano a titolare, DPO e legale.

CTRL	AREA	STATO	GAP
A	Mappa trattamenti e ruoli	**confermato da codice/config**	Mappa parziale in processing-map.csv; ruoli non verificabili
B	Principi e basi giuridiche	**ipotesi**	Basi giuridiche non verificate fuori dalla DPIA
C	Dati particolari, penali, minori	**ipotesi**	Certificati medici = categoria particolare; condizione e accessi non verificati
D	Trasparenza (artt. 13/14)	**confermato da codice/config**	Informativa non coerente col trattamento reale su destinatari e trasferimenti
E	Cookie e tracking	**confermato da codice/config**	Connessione a Google all'apertura di qualsiasi pagina, inclusi login e pagine pubbliche
F	Diritti degli interessati	**confermato da codice/config**	Cancellazione nei backup non verificata
G	Retention e cancellazione effettiva	**confermato da codice/config**	Backup oltre i tempi di retention dei dati originali: da verificare
H	Privacy by design/default e sicurezza	**confermato da codice/config**	Rimandare a appsec-sentinel: due finding di sicurezza ad alta severità incidono sulla sicurezza dei dati (art. 32)
I	Fornitori e accordi (art. 28/26)	**non verificabile**	Contratti non visti
J	Trasferimenti internazionali	**non verificabile**	Possibile incoerenza con l'informativa
K	Governance (artt. 24, 27, 30, 35-39)	**non verificabile**	Registro non visto
L	Incidenti e data breach	**non verificabile**	Contenuto non letto
M	Profilazione, AI, marketing	**ipotesi**	Trattamento dei lead non mappato
N	Casi italiani e settoriali	**ipotesi**	Dipende dal singolo cliente (PA/associazione/impresa)

Mappa dei trattamenti

ID	TRATTAMENTO	DATI E INTERESSATI	GAP
T01	Timbrature con GPS	coordinate, orari; dipendenti e volontari	accordo art. 4 L. 300/1970 per cliente
T02	Assenze con certificato medico	tipo assenza, certificato; lavoratori	condizione art. 9.2 e accessi
T03	Notifiche WhatsApp	numero di telefono; utenti	DPA e trasferimento non verificati; non citato in informativa
T04	Caricamento font e icone	indirizzo IP e user agent; tutti i visitatori	non citato in informativa; valutare self-hosting

ID	TRATTAMENTO	DATI E INTERESSATI	GAP
T05	Backup su Google Drive	copia del database (comprende dati di T01-T02); tutti gli interessati	cifratura dei backup non rilevata nella documentazione letta
T06	Preventivi e lead	nome, email, telefono, messaggio; contatti commerciali	vedi anche APP-004

4 Domande per titolare, DPO, legale e fornitori

Ogni punto non verificabile o incoerente ha la sua domanda, con il destinatario e il materiale necessario.

ID	DESTINATARIO	DOMANDA
Q1	Titolare	Per ogni organizzazione cliente, chi è titolare e chi responsabile? Esiste un contratto di nomina con il fornitore del servizio?
Q2	Titolare, DPO	Quali basi giuridiche sono documentate per timbrature, assenze, formazione e contatti commerciali?
Q3	DPO	Per i certificati medici (art. 9): quale condizione si applica, chi può accedervi e come sono protetti?
Q4	Titolare, DPO	L'informativa va aggiornata con i destinatari reali (Google, Twilio, altri)? Per i fornitori statunitensi: DPF o clausole tipo? Da verificare alla fonte ora.
Q5	Sviluppatore, DPO	Il caricamento di font e icone da Google va mantenuto o conviene ospitarli sul proprio server (self-hosting)?
Q6	Titolare, sviluppatore	Come si cancellano i dati dai backup quando un interessato esercita l'art. 17? Quanto durano i backup rispetto alla retention dei dati?
Q7	Sviluppatore	Come si chiudono i finding di sicurezza che incidono sull'art. 32 (route demo senza login, MFA solo lato client, dipendenze)?
Q8	Titolare, fornitori	Esistono DPA con Google, Twilio, il provider di posta e l'hosting?
Q9	Titolare	Registro dei trattamenti e nomina del DPO: sono disponibili?
Q10	Titolare, DPO	Procedura di violazione dei dati: testo vigente, chi decide, esiste un registro delle violazioni?
Q11	Titolare	Quale base giuridica e quale informativa per i contatti commerciali (lead e preventivi)?
Q12	Titolare, legale	Per i clienti con dipendenti: accordo sindacale o autorizzazione per le timbrature con GPS (L. 300/1970 art. 4)?

5 Copertura e limiti

La copertura riguarda solo ciò che è stato inventariato: non prova l'assenza di problemi non censiti.

- Sei trattamenti mappati; documenti letti per presenza del tema, non per intero.

Non verificato

- Contratti con i fornitori e registro dei trattamenti.
- Cookie reali in un browser pulito (test preparato, non eseguito).
- Contenuto integrale di DPIA e procedura di violazione.

6 Piano di intervento proposto

QUANDO	AZIONE	RESPONSABILE PROPOSTO
Subito	Allineare l'informativa ai destinatari e ai trasferimenti reali (Q4).	Titolare, DPO
Subito	Verificare cifratura e accessi dei backup su Google Drive (Q6).	Sviluppatore, titolare
Prossime settimane	Chiudere i finding di sicurezza che incidono sull'art. 32 (Q7).	Sviluppatore
Prossime settimane	Raccogliere DPA, registro e nomina del DPO (Q8, Q9).	Titolare
Pianificato	Valutare l'hosting locale dei font (Q5) e il test del browser su istanza autorizzata.	Sviluppatore

Le priorità derivano dal rischio per gli interessati, non da scadenze di legge.

METODO E AVVERTENZE

Valutazione eseguita con le skill appsec-sentinel e gdpr-sentinel (Apache-2.0). Ogni finding ha uno stato che dice cosa è stato dimostrato. Non è un penetration test completo, non certifica sicurezza o conformità e non sostituisce il parere di DPO e legale. Segreti e dati personali non sono riportati. Le fonti normative e gli standard vanno riverificati prima di citarli.